

Windows Threat Hunting & Incident Response: Simulated Endpoint Compromise

Project By: Izaan Shumaiz

1. Executive Summary

This report documents a self-directed purple-team exercise: I designed, built, and ran a full attack chain against a Windows 11 workstation (WKS-FIN-01) in an isolated Azure lab environment I set up for this purpose, then independently investigated it end-to-end as a SOC analyst would investigate a real incident, using Microsoft Sentinel, Sysmon, and native Windows auditing. The attack simulated a brute-force compromise against RDP, followed by privilege escalation, persistence, data staging, and an outbound command-and-control-style connection. The investigation produced a verified timeline, a working correlation detection rule, eight threat-hunting queries, and full simulated containment and recovery.

The report below is written in standard incident-report language (describing actions as "the attacker" performed them) to mirror how a real SOC engagement would be documented and reviewed, but every action attributed to "the attacker" throughout this report was executed by me, from the Kali Linux attacker VM, as part of the planned exercise.

The attack chain progressed from a brute-forced RDP logon against a standard user account (`j.carter`) to an interactive session takeover, PowerShell-based reconnaissance, a credential-reuse privilege escalation to a local administrator account (`labadmin`), creation of a backdoor account (`lab_attacker`) with administrative rights, a disguised scheduled task for persistence, staging and deletion of a simulated sensitive file, and an outbound connection consistent with command-and-control (C2) behavior. All stages were independently verified against Windows Security Event logs, Sysmon telemetry, and PowerShell Script Block Logging in Microsoft Sentinel.

The investigation also surfaced two findings that would matter in a real SOC: the Security log's stated subject for several actions (`labadmin`) did not match the true origin of those actions (the compromised `j.carter` session), visible only by tracing Sysmon process ancestry; and a default Sysmon configuration omitted generic file-write telemetry outside monitored paths, requiring a targeted configuration fix mid-investigation. Both are documented in full below.

Containment was completed in under two minutes: the backdoor account was disabled, removed from Administrators, and deleted; the persistence mechanism was removed; and the host was verified, via direct comparison against a pre-incident baseline, to be fully restored.

2. Environment

Component	Detail
Resource group	RG-IR-Lab (Azure)
Virtual network	VNet-IR-Lab, subnet 10.10.1.0/24, isolated, with inbound internet access restricted to the analyst's own IP via NSG
Target host	WKS-FIN-01, Windows 11 Pro 25H2, static IP 10.10.1.10
Attacker host	KALI-ATT-01, Kali Linux, static IP 10.10.1.20
SIEM	Microsoft Sentinel, workspace LAW-ir-lab

Component	Detail
Telemetry	Windows Security auditing (logon, process creation with command line, account management, scheduled task events), PowerShell Script Block Logging (4103/4104), Sysmon v15.22 (SwiftOnSecurity base configuration, extended with a custom rule for sensitive file paths)
Data collection	Two Azure Monitor Agent Data Collection Rules: one for Windows Security Events, one for Sysmon/PowerShell/Task Scheduler/Defender operational logs
Time standard	All systems and all timestamps in this report are UTC

The lab network was deliberately isolated rather than reusing an internet-exposed honeypot from a prior project, so that all telemetry generated could be attributed with certainty to the simulated attack rather than background internet scanning noise.

3. Incident Overview

Initial alert. Eight failed RDP authentication attempts against the account `j.carter` from source IP 10.10.1.20, followed within seconds by a successful authentication: the classic brute-force-then-compromise signature.

Scope of the investigation. The investigation determined:

- **Who/what caused it:** an attacker host (10.10.1.20) brute-forcing RDP credentials for `j.carter`, then operating hands-on-keyboard.
- **What happened:** credential compromise, interactive session takeover (displacing a legitimate administrator session in progress), PowerShell reconnaissance, privilege escalation via a second, separately-obtained administrator credential, creation of a backdoor administrator account, persistence via a disguised scheduled task, staging and deletion of a simulated sensitive file, and an outbound connection to attacker infrastructure.
- **When:** 09:18:49 UTC to 10:51:00 UTC on 7 October 2026 (approximately 92 minutes).
- **What was executed:** native Windows utilities and PowerShell only: no custom malware was introduced, consistent with a living-off-the-land approach.
- **Persistence:** confirmed: a scheduled task (SystemHealthCheck) configured to run as SYSTEM on logon.
- **Accounts/files/processes affected:** `j.carter` (initial access), `labadmin` (credentials reused for escalation), `lab_attacker` (created, elevated, later removed), `C:\\Temp\\Finance\\financial_report.txt` (staged and deleted).
- **Analyst next steps:** detailed in Section 9 (Containment) and Section 12 (Detection Recommendations).

4. Attack Timeline

All times UTC, 7 October 2026. Every entry below was independently confirmed in Microsoft Sentinel (Section 6).

Time	Event	Evidence	Interpretation
09:18:49–09:19:17	8 failed RDP logons, same account/IP	Security 4625 ×8, LogonType 3, src 10.10.1.20	Brute-force credential attack in progress
09:19:21	Successful logon (protocol level)	Security 4624, LogonType 3	Correct password identified
10:07:34	Interactive session established	Security 4624, LogonType 10	Attacker gains full interactive desktop access
10:07:59	Legitimate admin session terminated	Security 4634 (labadmin)	Collateral session takeover (single-session-limit side effect)
10:10–10:17	PowerShell reconnaissance (4 commands)	Sysmon Event 1, PowerShell 4104, - ExecutionPolicy Bypass	Attacker enumerates environment, process list, filesystem
10:20:13	Privilege pivot via runas	Sysmon Event 1, parent j.carter → runas.exe → labadmin	Attacker uses a second, separately-obtained credential to escalate
10:21:52	New local account created	Security 4720, TargetUserName lab_attacker	Backdoor account established
10:22:14	Account added to Administrators	Security 4732	Privilege escalation confirmed
10:34:19	Scheduled task created	Security 4698, Task Scheduler 106/140	Persistence mechanism established (disguised name)
10:34:45	Scheduled task executed	Task Scheduler 200/201	Persistence verified functional
10:41–10:44 (originally)	Sensitive file created, modified, deleted	Not captured; see note	Data staging and cleanup behavior

Time	Event	Evidence	Interpretation
10:50:46	Outbound connection established	Sysmon Event 3, dest 10.10.1.20:8080	Simulated C2-style outbound HTTP communication
12:05:38	File activity re-captured	Sysmon Event 11/23	Re-run after a Sysmon configuration gap was identified and fixed; see Section 11

Note on the file-activity timestamp: the original file staging/deletion (10:41–10:44) was not logged by Sysmon because the default configuration does not watch generic file writes outside specific paths and extensions. This was identified during verification (Section 6), fixed with a targeted configuration rule, and the activity was re-performed at 12:05:38 to capture clean telemetry. This gap and fix are discussed as a finding in Section 11.

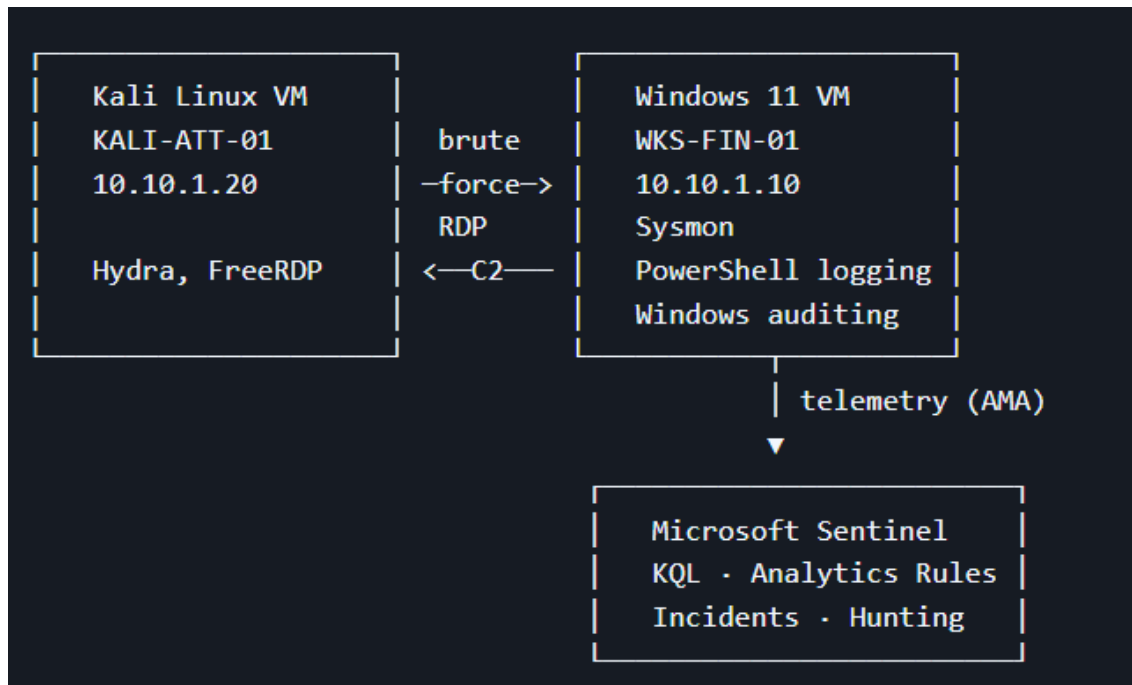


Figure 1: Architecture Diagram

5. Detection

One Microsoft Sentinel Scheduled Analytics Rule was built to detect the highest-value pattern in the attack chain: The rule correlates multiple failed and successful logons for the same account and source IP within a five-minute window, rather than a large number of low-value threshold rules.

Rule: Successful Logon Following Multiple Failed Attempts (Brute Force)

- **Severity:** High

- **MITRE mapping:** T1110 (Brute Force), T1078 (Valid Accounts)
- **Logic:** bins Security 4624/4625 events into 5-minute windows per target account and source IP; fires only when at least 5 failures and a subsequent success occur in the same window.

```
let failedThreshold = 5;
let timeWindow = 5m;
SecurityEvent
| where EventID in (4624, 4625)
| summarize
    FailCount = countif(EventID == 4625),
    SuccessTime = minif(TimeGenerated, EventID == 4624)
by TargetUserName, IPAddress, bin(TimeGenerated, timeWindow)
| where FailCount >= failedThreshold and isnotempty(SuccessTime)
| project TimeGenerated = SuccessTime, TargetUserName, IPAddress, FailCount
```

- **Entity mapping:** Account → TargetUserName, IP → IPAddress (enables automatic entity correlation in the incident view).
- **Result:** the rule correctly fired against the Stage 1 brute-force activity, generating High-severity incidents with Account (j.carter) and IP (10.10.1.20) entities auto-populated. This rule would not fire on a single mistyped password or a normal login with no preceding failures, as confirmed against the legitimate baseline logon activity captured during the investigation (Section 6).

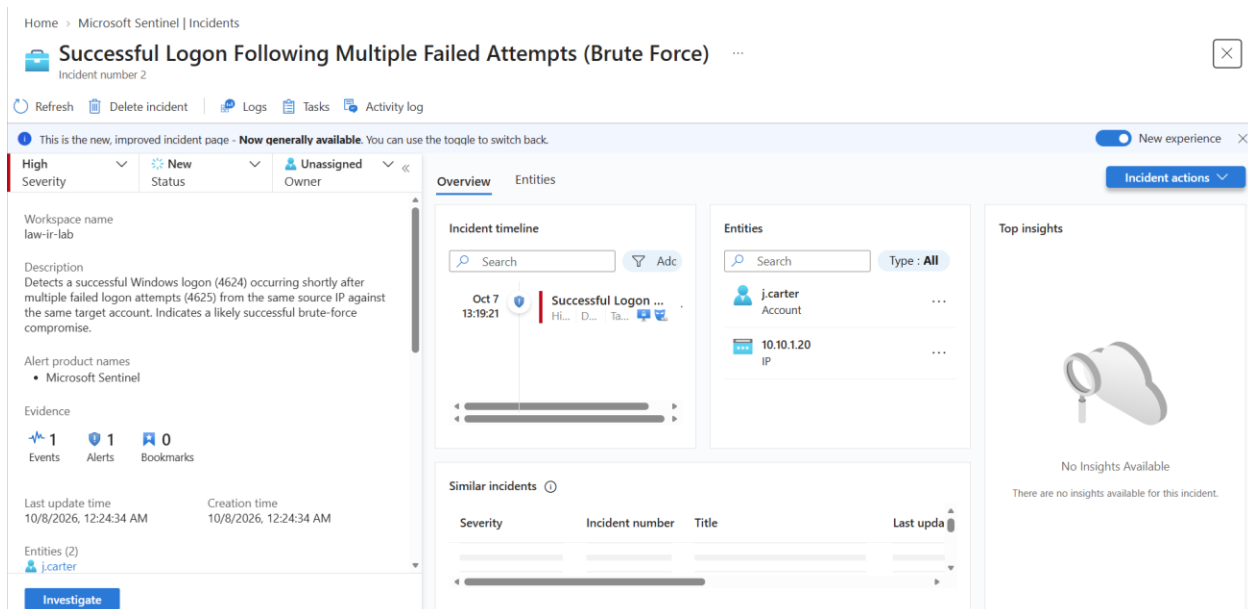


Figure 2: Sentinel incident view showing the fired alert with entity mapping

6. Investigation

Eight threat-hunting queries were run against Sentinel to answer the investigative questions that frame any IR engagement, correlating Windows Security Events, Sysmon, PowerShell Script Block Logging, and Task Scheduler telemetry.

#	Question	Finding
1	Which users experienced multiple failed authentication attempts?	j.carter from 10.10.1.20 (8 failures, 09:18:49–09:19:17)
2	Which accounts authenticated successfully after repeated failures?	j.carter from the same IP, immediately after its 8th failure
3	What PowerShell executed during the incident window?	4 reconnaissance commands plus net user lab_attacker ... /add and the runas pivot, all captured via Script Block Logging
4	Were any new accounts created?	lab_attacker, created by labadmin at 10:21:52
5	Did new accounts receive administrative privileges?	Yes, added to Administrators at 10:22:14
6	Were scheduled tasks created during the incident?	SystemHealthCheck, created, launched, and completed between 10:34:19–10:34:45
7	Which processes initiated network connections?	powershell.exe → 10.10.1.20:8080 at 10:50:46, isolated from benign OneDrive/RDP background traffic
8	What happened immediately before and after the suspicious activity?	A single correlated query across Security, Sysmon, and Task Scheduler sources reconstructed the full chronological chain end to end

Key analyst findings

Finding 1: Attribution requires process-ancestry correlation, not just the Security log. The account creation (4720) and privilege escalation (4732) events are both attributed to labadmin as the SubjectUserName. Read in isolation, this looks like routine administrator activity. Tracing Sysmon process ancestry revealed the true picture: a runas.exe process with ParentUser: j.carter and ParentImage: powershell.exe launched the elevated cmd.exe that performed these actions. The Security log's stated subject and the actual origin of the action diverge: the attacker used a second, separately-obtained credential (labadmin) from within the already-compromised j.carter session. This is a realistic simulation of lateral/vertical movement via credential reuse, and demonstrates why attribution in a real investigation must follow the process tree, not just the subject field of a single event.

Finding 2: Cross-log disagreement on task attribution. The Security log's 4698 event and the Task Scheduler Operational log disagree on who registered the SystemHealthCheck task: the Task Scheduler log shows the registering user as SID S-1-5-18 (NT AUTHORITY\SYSTEM), a reflection of the task's configured /ru SYSTEM run-as context, not its creator. Only the Security log's 4698 event and the Sysmon process chain correctly attribute the creation action to labadmin. Relying on a single log source here would have produced an incorrect attribution.

Finding 3: Default telemetry gaps exist and must be actively tested for. The SwiftOnSecurity Sysmon configuration in use does not log generic file creation/deletion outside specific monitored paths and extensions. The initial staging of C:\\Temp\\Finance\\financial_report.txt produced no Sysmon Event 11/23 telemetry as a result. This was only discovered through deliberate verification against the planned attack chain (Section 7), not assumed. A targeted rule scoping C:\\Temp\\Finance* was added, and the file activity was re-performed to capture complete evidence (re-logged at 12:05:38). This is documented further as a detection gap in Section 11.

Finding 4: A candidate T1055 (Process Injection) alert was investigated and ruled a false positive. During baseline capture (prior to the attack), a single Sysmon Event 8 (CreateRemoteThread) fired: dwm.exe (Desktop Window Manager) injecting into csrss.exe. Both are trusted SYSTEM-owned OS components, and the event timing correlated exactly with a legitimate RDP session startup, a known, benign Windows behavior. This is documented as an example of correctly triaging and dismissing a technically-matching but non-malicious alert, rather than treating every CreateRemoteThread event as hostile.

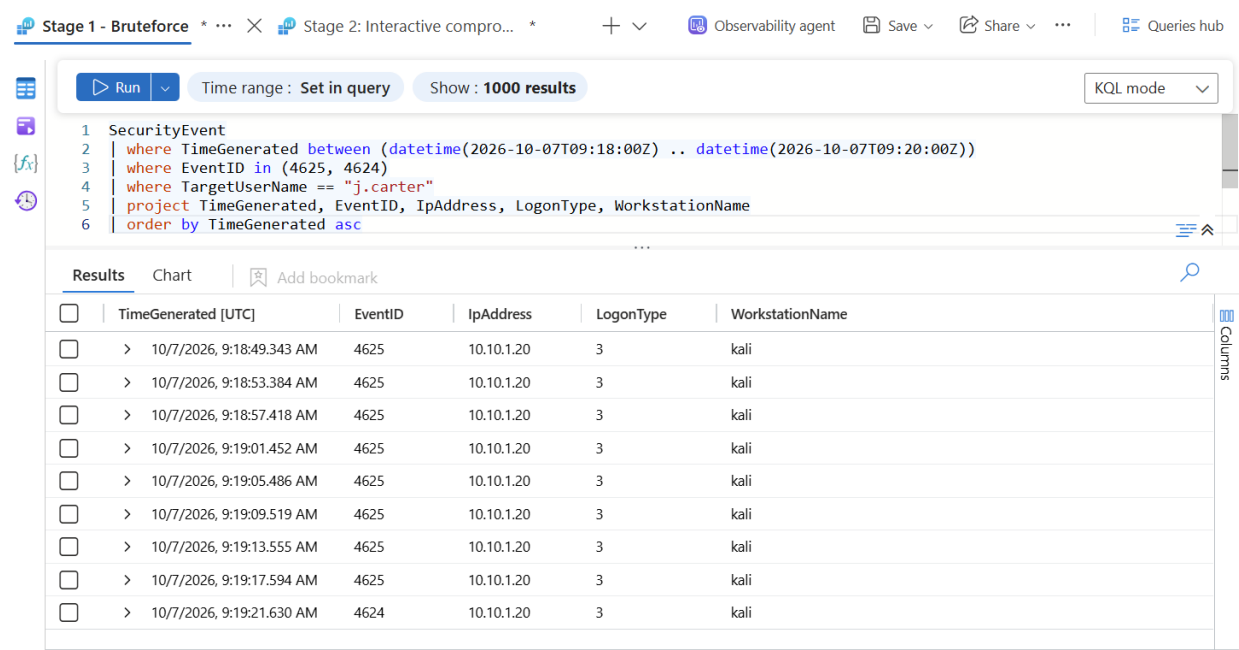


Figure 3: Bruteforce Verification

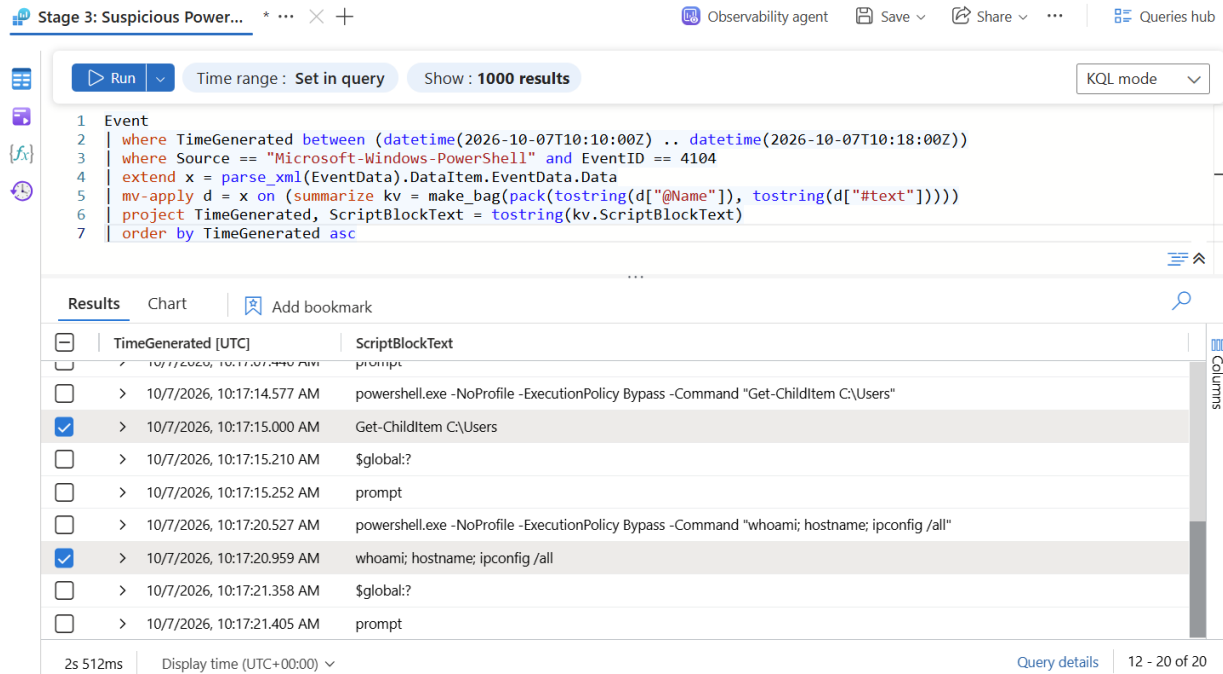


Figure 4: Suspicious PowerShell Activity

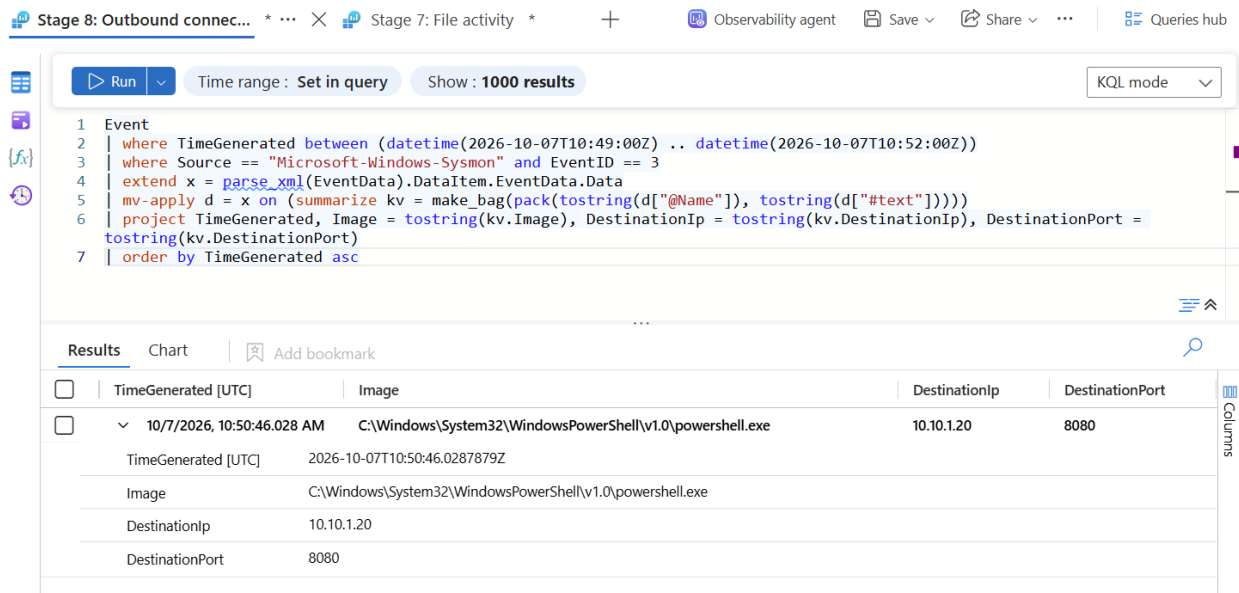


Figure 5: Outbound Connection

7. MITRE ATT&CK Mapping

#	Technique	Evidence	Event(s)	Interpretation
1	T1110: Brute Force	8 consecutive failed RDP	4625 x8,	Automated

#	Technique	Evidence	Event(s)	Interpretation
		logons, same account/IP, ~4s apart	09:18:49–09:19:17	credential-guessing attack
2	T1078: Valid Accounts	Successful logons immediately following brute force	4624 (Type 3) 09:19:21; 4624 (Type 10) 10:07:34	Legitimate credentials obtained and used
3	T1021.001: Remote Services: RDP	Interactive session from attacker IP	4624 LogonType 10, 10:07:34	RDP used as the access vector
4	T1059.001: PowerShell	4 commands executed, 2 with -ExecutionPolicy Bypass	Sysmon 1, PowerShell 4104, 10:10–10:17	Reconnaissance via PowerShell with execution-policy bypass
5	T1078c: Credential Reuse	runas launched from the j.carter session as labadmin	Sysmon 1, 10:20:13	Privilege pivot via a second credential
6	T1136.001: Create Local Account	lab_attacker created	4720, 10:21:52	Backdoor account established
7	T1098: Account Manipulation	lab_attacker added to Administrators	4732, 10:22:14	Privilege escalation confirmed
8	T1053.005: Scheduled Task	SystemHealthCheck created, run as SYSTEM, on-logon trigger	4698, Task Scheduler 106/140/200/201, 10:34	Persistence, disguised with an innocuous name
9	T1074.001: Data Staged	Sensitive file created, modified	Sysmon 11, 12:05:38	Pre-exfiltration staging behavior
10	T1070.004: Indicator Removal: File Deletion	Staged file deleted shortly after creation	Sysmon 23, 12:05:38	Attempted cleanup to reduce forensic footprint
11	T1071 / T1105: C2 / Ingress Tool Transfer	Outbound HTTP connection from PowerShell	Sysmon 3, 10:50:46, dest 10.10.1.20:8080	Simulated C2-style outbound HTTP communication
12	T1562.001: Impair Defenses (negative finding)	No Defender tampering or log-clearing observed	None observed	Notable absence; worth recording explicitly

A candidate T1055 (Process Injection) indicator was also investigated (Sysmon Event 8, dwm.exe → csrss.exe at RDP logon) and confirmed as a benign Windows behavior, not an attacker action; see Finding 4 in Section 6.

8. Indicators of Compromise

All indicators below were generated within an isolated, non-production Azure lab for educational purposes and do not represent real-world threat infrastructure.

Accounts

Indicator	Value	Note
Targeted account	j.carter	Initial brute-force target
Created account	lab_attacker	Backdoor account (deleted during containment)
Reused credential	labadmin	Used via runas for privilege escalation

Network

Indicator	Value	Note
Attacker source IP	10.10.1.20	Brute force, RDP session, C2 connection
Victim host	10.10.1.10	WKS-FIN-01
C2 destination	10.10.1.20:8080	HTTP listener simulating command-and-control

Host artifacts

Indicator	Value	Note
Scheduled task	SystemHealthCheck	Persistence mechanism, disguised name
Task action	cmd.exe echo redirect to a text file under C:/Temp	Task payload
Staged file	financial_report.txt, under C:/Temp/Finance	Created, modified, deleted
PowerShell flags	-ExecutionPolicy Bypass, -NoProfile	Present in 2 of 4 PowerShell invocations
Process ancestry	powershell.exe → runas.exe → cmd.exe (as labadmin)	Privilege-pivot signature

Timing

Incident window: 2026-10-07 09:18:49 UTC – 10:51:00 UTC, host WKS-FIN-01 (10.10.1.10).

9. Containment

Containment was performed from a legitimate administrator session, reversing every persistence and privilege change in order, each action verified against both the corresponding Windows Security Event and a direct command-line check.

Action	Command	Time (UTC)	Verified by
Disabled lab_attacker (not deleted immediately, to preserve forensic value)	net user lab_attacker /active:no	20:30:03	Security 4725; Get-LocalUser confirmed Enabled: False
Removed from Administrators	net localgroup administrators lab_attacker /delete	20:30:15	Security 4733; Get-LocalGroupMember Administrators showed only labadmin
Removed persistence (scheduled task)	schtasks /delete /tn "SystemHealthCheck" /f	20:30:26	Security 4699; schtasks /query returned "file not found"
Deleted lab_attacker	net user lab_attacker /delete	20:31:30	Security 4726; Get-LocalUser confirmed the account no longer existed

Total time from first containment action to full account removal: approximately 90 seconds.

A direct comparison of the Administrators group against the pre-incident baseline (Compare-Object) returned no differences, confirming the privilege escalation was fully reversed, not merely claimed.

New Query 1 * ... × +

Observability agent Save Share ... Queries hub

Run Time range: Set in query Show: 1000 results KQL mode

```

1 SecurityEvent
2 | where TimeGenerated > ago(30m)
3 | where EventID in (4725, 4733, 4699, 4726)
4 | project TimeGenerated, EventID, TargetUserName, SubjectUserName, Activity
5 | order by TimeGenerated asc

```

Results Chart Add bookmark

	TimeGenerated [UTC]	EventID	TargetUserName	SubjectUserName	Activity
☐	> 10/7/2026, 8:30:03.701 PM	4725	lab_attacker	labadmin	4725 - A user account was disabled.
☐	> 10/7/2026, 8:30:15.721 PM	4733	Administrators	labadmin	4733 - A member was removed from a security-enabled local gro...
☐	> 10/7/2026, 8:30:26.545 PM	4699			4699 - A scheduled task was deleted.
☐	> 10/7/2026, 8:31:30.580 PM	4733	Users	labadmin	4733 - A member was removed from a security-enabled local gro...
☐	> 10/7/2026, 8:31:30.583 PM	4726	lab_attacker	labadmin	4726 - A user account was deleted.

Columns

Figure 6: Full containment trail (4725/4733/4699/4726)

10. Recovery

Following containment, the host was checked against the pre-incident baseline captured in the earliest phase of this investigation (local users, Administrators group membership, active scheduled tasks, running processes, and established network connections), and leftover artifacts were cleaned up.

- Compare-Object against the baseline Administrators group: no differences.
- Compare-Object against the baseline scheduled task list: only benign, unrelated Windows/OneDrive housekeeping tasks had been added over the operational period, with no trace of SystemHealthCheck or any other attacker-created task remained.
- Local user accounts: confirmed lab_attacker no longer present; only the original pre-incident accounts remained.
- Leftover scheduled-task artifact file removed from disk.
- No persistent network connection to the attacker host remained (the C2-style connection was a single request, not a maintained channel).

The host was confirmed restored to its pre-incident state, with the only residual differences being unrelated, benign application activity that occurred naturally during the operational window.

11. Lessons Learned

Default telemetry configurations have real gaps. The SwiftOnSecurity Sysmon configuration, a widely-used community baseline, does not capture generic file creation and deletion outside monitored paths. This was only discovered through active verification of every planned attack step against actual collected telemetry, a reminder that "detection coverage" must be tested, never assumed from a config's reputation alone.

Single-log attribution is unreliable. Both the task-attribution discrepancy (Security log vs. Task Scheduler log, Finding 2) and the credential-reuse pivot (Finding 1) were only visible by correlating

multiple log sources and following process ancestry. An analyst relying on any one event or one log source in isolation would have reached an incomplete or incorrect conclusion.

A single-session RDP limit can create a legitimate-user disruption as a side effect of an attack. The administrator's own session was silently disconnected when the attacker's interactive session was granted, an artifact worth recognizing in a real environment as a signal (an unexpected session termination) that is easy to overlook as routine.

False positives require triage, not blanket suppression. The Sysmon Event 8 (CreateRemoteThread) finding demonstrates the value of investigating a technically-matching alert rather than either ignoring it outright or treating it as confirmed malicious without analysis.

Scope decisions should be stated explicitly. The simulated attacker did not possess a working privilege-escalation exploit; the investigation deliberately modeled the next most realistic step (reuse of a separately-obtained administrator credential) rather than fabricating or skipping privilege escalation. Documenting this choice, rather than hiding it, better reflects how real IR scoping decisions are made and communicated.

12. Detection Recommendations

Recommendations for a production SOC based on this investigation, beyond the single rule built in Section 5:

1. **Expand brute-force/success correlation** to cover additional protocols (SSH, WinRM, SMB), not RDP alone.
 2. **Alert on runas and credential-switching events** where the parent process user and the resulting process user differ, particularly when the parent session originated from an external or recently-authenticated source; this directly targets the Finding 1 pivot technique.
 3. **Correlate account creation (4720) with group membership change (4732) within a short window** as a single higher-confidence privilege-escalation alert, rather than treating them as independent low-priority events.
 4. **Alert on scheduled tasks configured to run as SYSTEM with an on-logon trigger**, created outside of known change-management windows, a common, low-noise persistence pattern.
 5. **Extend Sysmon file-monitoring rules to cover sensitive data directories explicitly** (finance, HR, legal shares), rather than relying on a generic community baseline config.
 6. **Alert on outbound connections from powershell.exe and cmd.exe to non-standard ports on previously-unseen internal or external hosts.**
 7. **Monitor for unexpected session-termination events (4634/4779) immediately followed by a new interactive logon from a different source**, as a signal of possible session takeover.
 8. **Routinely test detection coverage against a known attack chain** (a purple-team exercise, as performed in this lab) rather than assuming default configurations provide complete visibility; this investigation's Finding 3 would not have been caught any other way.
-

This report documents a fully simulated, educational exercise conducted in an isolated Azure lab environment. All indicators, accounts, and infrastructure referenced are lab-generated and hold no connection to real-world systems or threat actors.